

Web Application Vulnerability Assessment Report

Task 1 — Vulnerability Assessment

1. Assessment Information

Target: <https://altdro.testfire.net/>

Observed IP Address: 65.61.137.117

Assessment Type: Web Application Security Assessment

Testing Platform: Kali Linux

Tools Used: Nmap, OWASP ZAP, Firefox

2. Objective

The objective of this assessment was to identify and document security weaknesses in the target web application through reconnaissance, HTTP response-header analysis, browser inspection, and OWASP ZAP passive scanning.

3. Scope

The assessment was performed against:

<https://altdro.testfire.net/>

Testing was limited to the target application and the activities documented in this report.

4. Methodology

4.1 Reconnaissance

Nmap was used to identify HTTP and HTTPS services and obtain service information.

Nmap Command

```
nmap -sV -Pn -p 80,443 altdro.testfire.net
```

Observed Services

```
80/tcp open http Apache Tomcat/Coyote JSP engine 1.1 443/tcp open https Apache Tomcat/Coyote JSP engine 1.1
```

HTTP Header Scan

`nmap -Pn -p 80,443 --script http-headers altoro.testfire.net`

Observed server header:

Server: Apache-Coyote/1.1

Evidence: evidence/01_nmap_http_headers.png

4.2 HTTP Header Analysis

HTTP response headers were inspected to identify missing security controls and unnecessary information disclosure.

Observed HTTP response information included:

Server: Apache-Coyote/1.1 Set-Cookie: JSESSIONID=[redacted]; Path=/; HttpOnly

Observed HTTPS response information included:

Server: Apache-Coyote/1.1 Set-Cookie: JSESSIONID=[redacted]; Path=/; Secure; HttpOnly

Supporting file: http_headers.txt

4.3 Passive Vulnerability Assessment

OWASP ZAP was used to passively analyze requests and responses while the application was accessed through the browser.

5. Findings Summary

ID	Finding	Risk	Confidence	CWE	WASC
F-01	Content Security Policy (CSP) Header Not Set	Medium	High	693	15
F-02	Missing Anti-clickjacking Header	Medium	Medium	1021	15

ID	Finding	Risk	Confidence	CWE	WASC
F-03	Server Leaks Version In- formation via Server Header	Low	High	497	13

Total confirmed findings: 3

6. Detailed Findings

F-01 — Content Security Policy (CSP) Header Not Set

Risk: Medium

Confidence: High

CWE: CWE-693

WASC: WASC-15

Affected URL: <https://altdro.testfire.net/>

Description

OWASP ZAP identified that the application does not set a Content Security Policy (CSP) response header.

Impact

The absence of CSP means the browser does not receive this additional content-restriction control. Depending on other application weaknesses, this may increase exposure to certain content-injection scenarios.

Recommendation

Implement an appropriate Content-Security-Policy response header based on the application's required scripts, styles, images, frames, and other resources. Test the policy before enforcement.

Evidence

evidence/04_zap_csp_header_not_set.png

F-02 — Missing Anti-clickjacking Header

Risk: Medium

Confidence: Medium

CWE: CWE-1021

WASC: WASC-15

Affected URL: <https://altdro.testfire.net/>

Description

OWASP ZAP identified that the application does not provide an appropriate anti-clickjacking response-header control.

Impact

Without an appropriate framing restriction, a webpage may potentially be embedded by another site and used in deceptive interaction scenarios.

Recommendation

Implement an appropriate clickjacking protection mechanism, such as the Content-Security-Policy frame-ancestors directive. X-Frame-Options may also be used where appropriate.

Evidence

evidence/07_zap_alert_details.png

F-03 — Server Version Information Disclosure

Risk: Low

Confidence: High

CWE: CWE-497

WASC: WASC-13

Affected URL: <https://altdro.testfire.net/>

Description

The application's HTTP response exposes server implementation information through the Server response header.

Observed Header

Server: Apache-Coyote/1.1

Impact

The disclosed information can assist reconnaissance by providing information about the server technology used by the application.

Recommendation

Configure the application/server infrastructure to minimize unnecessary server-identifying information in HTTP response headers where practical.

Evidence

evidence/09_zap_server_version_disclosure.png

7. Risk Summary

Severity	Number of Findings
High	0
Medium	2
Low	1
Total	3

8. Evidence

Supporting evidence is stored in the evidence directory.

Key evidence:

- evidence/01_nmap_http_headers.png
- evidence/04_zap_csp_header_not_set.png
- evidence/07_zap_alert_details.png
- evidence/09_zap_server_version_disclosure.png

9. Supporting Files

http_headers.txt nmap_results.txt README.md evidence/ report/

10. Limitations

This assessment was limited to reconnaissance, HTTP response-header analysis, browser inspection, and OWASP ZAP passive scanning.

No exploitation, brute-force testing, credential attacks, or destructive testing was performed.

The findings documented in this report represent the issues confirmed during the documented assessment and should not be interpreted as a complete security audit of the application.

11. Conclusion

The assessment identified three confirmed security-related findings involving HTTP security headers and server information disclosure.

The confirmed findings were:

1. Content Security Policy (CSP) Header Not Set
2. Missing Anti-clickjacking Header
3. Server Version Information Disclosure

The identified issues should be reviewed by the application/server administrators and remediated according to their applicability and risk.

12. Disclaimer

This assessment was performed against the intentionally vulnerable Altoro Mutual demonstration application for cybersecurity learning and internship documentation purposes.

The assessment was conducted only against the specified target and within the activities documented in this report.